



Audit Plan — Aetheris Therapeutics S.p.A.

Enterprise ISO/IEC 27001:2022 & NIST CSF v1.1 Gap Analysis

Standard di Riferimento: ISO/IEC 27001:2022 & NIST CSF v1.1

Organizzazione: Aetheris Therapeutics S.p.A.

Rif. Documento: AUD-PLAN-2026-01

Versione: 1.0

Stato: Approvato

Classificazione: Riservato / Per Uso d'Audit

Data di Efficacia: Agosto 2026

1. Obiettivo dell'Audit

Il presente Audit Plan definisce le linee guida, le metodologie e il perimetro operativo per l'esecuzione della **Cybersecurity Gap Analysis e ISO 27001 Readiness Audit** presso **Aetheris Therapeutics S.p.A.**

L'audit ha l'obiettivo di valutare:

- * La conformità formale e sostanziale dell'organizzazione ai requisiti della norma **ISO/IEC 27001:2022** (Clausole Obbligatorie 4–10 ed Annex A).
- * La maturità e la resilienza della postura di sicurezza valutata sui 5 domini core del **NIST Cybersecurity Framework (CSF) v1.1** (*Identify, Protect, Detect, Respond, Recover*).
- * L'efficacia dei controlli tecnici, organizzativi e fisici posti a tutela degli asset strategici dell'azienda (proprietà intellettuale, brevetti molecolari, dati clinici di pazienti PII/GDPR).
- * Le lacune, le non-conformità (NC) e le opportunità di miglioramento (OFI) per la definizione del Piano di Remediation e della Roadmap strategica del CISO.

2. Scope dell'Audit (Perimetro di Valutazione)

2.1 In Scope

- **Infrastruttura & Cloud:** Architettura ibrida On-Premise, ambiente Microsoft Azure, tenant Office 365, directory Active Directory, connessioni VPN e Next-Gen Firewall Palo Alto.
- **Centri di Ricerca & Laboratori:** Reti e sistemi dei laboratori R&D, workstation per l'analisi clinica e server dedicati alla proprietà intellettuale.
- **Dispositivi Utente (Endpoints):** Tutti i laptop aziendali, workstation e dispositivi mobile in uso al personale.
- **Governance, Risk & Compliance:** Politiche di sicurezza, procedure operative, Registro dei Rischi, gestione terze parti/SaaS e conformità GDPR.
- **Persone & Ruoli:** Personale chiave dei reparti IT, Cybersecurity, HR, Legal & Compliance e R&D.

2.2 Out of Scope

- Sistemi IT e portali clinici esterni gestiti interamente da Organizzazioni di Ricerca a Contratto (CRO) terze non contrattualizzate direttamente per il SGSI.
- Dispositivi personali non autorizzati (BYOD) non connessi alle reti aziendali.

3. Criteri di Audit e Normative applicabili

La verifica viene condotta a fronte dei seguenti riferimenti normativi e tecnici:

1. **ISO/IEC 27001:2022:** Requisiti normativi delle Clausole 4–10 e 93 controlli dell'Annex A.

- 2. **NIST Cybersecurity Framework v1.1:** Domini ID, PR, DE, RS, RC.
- 3. **Regolamento UE 2016/679 (GDPR):** Tutela dei dati personali e sensibili dei pazienti/dipendenti.
- 4. **NIST SP 800-61 Rev. 2:** Best practice per la gestione degli incidenti di sicurezza.

4. Metodologia e Tecniche di Audit (ISO 19011)

L'audit adotta la metodologia stabilita dallo standard **ISO 19011:2018** mediante le seguenti tecniche:

- * **Interviste Strutturate:** Colloqui diretti con i responsabili dei singoli processi (IT, Security, HR, Legal).
- * **Analisi Documentale:** Esame di policy, procedure, registri di formazione, contratti di lavoro e SLA con i fornitori.
- * **Fieldwork & Walkthrough Tecnici:** Verifica pratica delle configurazioni (Active Directory, Azure IAM, ruoli Palo Alto, regole VPN, EDR).
- * **Campionamento Statistico:** Verifica a campione su utenze attive, contratti di lavoro, dischi cifrati BitLocker e log di sistema.

5. Ruoli, Responsabilità e Calendario Interviste

5.1 Team d'Audit

- **Lead Auditor:** Emanuele Tarchi (ISO 27001 Lead Auditor Trainee / GRC Specialist)
- **Audit Support & Technical Escort:** IT Director & Senior Systems Administrator

5.2 Calendario delle Sessioni d'Intervista e Verifiche

Data / Fase	Ruolo Intervistato / Area	Oggetto della Verifica	Criterio ISO/NIST
Giorno 1 - Mattina	IT Director	Architettura di rete, Backup, DR, Gestione Cloud Azure	ISO Cl. 4-5 / NIST ID, PR
Giorno 1 - Pomeriggio	Systems Administrator	Configurazione Active Directory, VPN, Firewall Palo Alto, Patching	Annex A.8.5, A.8.9, A.8.20
Giorno 2 - Mattina	Cybersecurity Analyst	Monitoring, Logging, EDR/SIEM, Incident Response	ISO Cl. 6, 8 / NIST DE, RS
Giorno 2 - Pomeriggio	HR Manager	Screening personale, onboarding, contratti NDA, formazione awareness	Annex A.6.1, A.6.3, A.6.6
Giorno 3 - Mattina	Legal & Compliance Lead	Conformità GDPR, contratti con fornitori terzi, gestione PII	ISO Cl. 4.2 / Annex A.5.19, A.5.34

6. Criteri di Classificazione dei Rilievi (ISO 19011)

Categoria Rilievo	Definizione	Azione Richiesta
NC Major (Non-Conformità Maggiore)	Mancanza totale o fallimento sistemico nell'attuazione di una clausola obbligatoria ISO o di un controllo critico	Remediation obbligatoria prima della certificazione
NC Minor (Non-Conformità Minore)	Singola lacuna procedurale o tecnica che non compromette l'intero SGSI	Piano di azione correttiva entro 90 giorni
OFI (Opportunity for Improvement)	Suggerimento tecnico/organizzativo per elevare il livello di maturità	Valutazione facoltativa a cura del CISO/IT
PASS (Conforme)	Il controllo soddisfa pienamente i requisiti normativi e le best practice	Mantenimento e monitoraggio continuo

7. Deliverables Ufficiali del Progetto

Al termine delle fasi di preparazione, fieldwork e analisi, l'audit produce la seguente suite di documenti:

1. audit/Audit_Plan.md (Il presente documento)
2. audit/Audit_Trail.md (Registro cronologico delle verifiche di campo e campionamenti)
3. audit/NC_OFI_Matrix.md (Registro ufficiale dei Rilievi e Non-Conformità)
4. risk/Risk_Register.md & Risk_Treatment_Plan.md (Registro Rischi ISO 27005 e Piano di Trattamento)
5. executive/Executive_Summary.md & Strategic_Roadmap_3-6-12.md (Reportistica C-Level e Roadmap CISO)

8. Controllo Documentale e Approvazione (ISO 27001:2022 Clausola 7.5)

Ruolo	Nome e Cognome	Stato	Data
Redatto da (Lead Auditor)	Emanuele Tarchi	Completato	Agosto 2026
Revisionato da (IT Director)	IT Director ad interim	Revisionato	Agosto 2026
Approvato da (Alta Direzione)	Chief Executive Officer (CEO)	Approvato	Agosto 2026